

# Cybersecurity requirements for Operating Systems

Deep Dive Session

**EN 304 626**

Presented by: Valerie Aurora  
January 2026



# Agenda

## Session Overview

- CRA & Standardisation Request Overview
- STAN4CR2 Project Context
- Standard Scope & Document Structure

## Deep Dive Content

- Use cases
- Annex C, risk assessment
- Technical Requirements (Clause 5)
- Assessment criteria
- Areas for Stakeholder Feedback

# CRA & Standardisation Request Overview

## Cyber Resilience Act Purpose

- CRA ensures products with digital elements are secure by design and resilient against cyber threats throughout their lifecycle.

## Key Focus for operating systems

- Unrelated to specific features, focus on cybersecurity requirements

## Harmonized Standards Benefits

- Reduce market fragmentation and help manufacturers efficiently meet regulatory expectations across the EU.
- Ensuring products are secure by design
- Identifying and mitigating vulnerabilities

# STAN4CR2 Project Context

## Harmonized Standards Development

- STAN4CR2 focuses on creating cybersecurity standards for different vertical products with digital elements to ensure CRA compliance.

## Organizational Leadership and Funding

- ETSI leads the project through its CYBER-EUSR technical group, working jointly with CEN CENELEC (JTC13/WG9), with funding from the European Commission and EFTA.

## Collaborative Approach

- The project fosters collaboration amongst industry, regulators, and academia to address cybersecurity challenges and align with EU regulations.

# ETSI EN 304 625 Scope

## Product Coverage

Software that provides an abstract interface of the underlying hardware and control the execution of software, and that may provide services such as computing resource management and configuration, scheduling, input-output control, managing data, and providing an interface through which applications interact with system resources and peripherals.

## Out of Scope

- hypervisors
- container runtime systems
- boot managers

# Product Context (Clause 4)

## **Intended purpose, Essential functions, & Architecture (4.1–4.3)**

- Provides more thorough detail on the products covered by this document and their composition

## **Operational environment & Distribution of security functions (4.4–4.5)**

- Describes the physical and digital environment in which the operating system functions
- Lays out how that environment is responsible for certain security functions
- Addresses security functionality for child components

## **Users & Use Cases (4.6–4.7)**

- Product use scenarios with differing security needs

# Clause 5: Requirements specifications

- Lists all threats identified by the standard and mitigations for those threats
- Not all mitigations apply to all products
- Manufacturers shall complete a risk assessment to understand which mitigations they are required to apply

# Risk identification and assessment methodology

## (Annex C)

- Risk Factors (C.2) — Manufacturers evaluate identified risks based on intended purpose, foreseeable use, and conditions of use
- Risk Factor Assessment (C.4) — Use those risks to enumerate threats and, based on the evaluated risks, which mitigations are required to lower likelihood and impact of an incident
- Understanding use cases (C.5) — A mapping of risk factors for use cases described in 4.7

### Result

- Each threat has one or more mitigations to lower risk level, those mitigations are the listed requirements in Clause 5



# Understanding risk assessment and use cases

- Use cases provide pre-packaged threat and mitigation identification
- For use cases not described in the standard, determining mitigation requirements is straightforward

## Process

- For each *risk factor*, manufacturer determines which level applies to their product and use case
- For each *threat*, manufacturer determines the likelihood and impact based on level of previously identified *risk factor*
- Manufacturer applies appropriate *requirements* to mitigate risk

# Lowering risk levels

## Every risk must be mitigated

- Most commonly, this will be by identifying mitigations which lower risk to an acceptable amount
- Some risks are mitigated by delegating to the operating environment, or to the user via clear documentation

**Only the requirements associated with a given threat are mandatory**

# Example Risk Factors identified in Annex C

NUSR: Number of User Accounts

CUSR: User Account Concurrency

PPII: Potential for Collection of Personally Identifiable Information...

SNDS: Sensitivity of Data Stored

SNDT: Sensitivity of Data Transmitted

SENF: Sensitivity of Functions

PHYS: Physical Access by Threat Actors to the Device

# Other risk assessments

- Annex C is informative and not required
- Completing and clearly documenting a risk assessment *is* required

# Requirement Overview (Clause 5)

Requirements are a group of mitigations that address a specific threat  
Which mitigation is required depends on the risk assessment. Example:

- 5.2.3 ER-**SSDD**: Secure design and development
  - 5.2.3.1 Requirement
  - 5.2.3.2 MI-**SSCA**: Static source code analysis for memory errors
  - 5.2.3.3 MI-**FZ95** Runtime code coverage checking with memory access error detection
  - 5.2.3.4 MI-**IMSL** Implement in a memory-safe language
  - 5.2.3.5 MI-**BTIN** Boundary testing of inputs that may cause memory errors
  - 5.2.3.6 MI-**SCFS**: Secure compilation flags

# Selected use cases

- 4.7.1 UC-LR: Operating system for learning and research
- 4.7.2 UC-IoT-1: Non-internet-connected device such as a bluetooth speaker
- 4.7.6 UC-OT-1: Business-grade remote door locking system
- 4.7.7 UC-MOB-1: Personal mobile device
- 4.7.9 UC-PC-1: Personal computer in a fixed and generally safe location
- 4.7.12 UC-LA-2: Enterprise laptop
- 4.7.14 UC-SE-1: Enterprise server in a datacenter with no user accounts
- 4.7.16 UC-SE-3: Enterprise server in a datacenter hosting many untrusted user accounts

# Use case to risk factors mapping

| Use case | NUSR | CUSR | DATA | PPII | SNDS | SNDT | SENF | PHYS |
|----------|------|------|------|------|------|------|------|------|
| UC-LR    | 0    | 0    | 0    | 0    | 0    | 0    | 0    | 0    |
| UC-IoT-1 | 0    | 0    | 0    | 0    | 0    | 0    | 0    | 0    |
| UC-IoT-2 | 0    | 0    | 1    | 0    | 1    | 1    | 0    | 0    |
| UC-IoT-3 | 0    | 0    | 1    | 0    | 1    | 1    | 1    | 0    |
| UC-RO-1  | 0    | 0    | 1    | 0    | 1    | 2    | 2    | 0    |
| UC-OT-1  | 0    | 0    | 0    | 0    | 1    | 1    | 2    | 2    |

## Risk assessment based on each use case/security profile

- C.4.3 TH-UEVU: Unknown exploitable vulnerabilities

Attacker may use unknown exploitable vulnerabilities in the product implementation to get unauthorized

| Risk factors                                                                | Likelihood | Security profiles                         |
|-----------------------------------------------------------------------------|------------|-------------------------------------------|
| $\max(\text{NUSR}, \text{CUSR}, \text{SENF}, \text{PHYS}, \text{FNET}) = 0$ | Low        | LR, IoT-1                                 |
| all others                                                                  | Medium     | IoT-2, IoT-3, WE-1                        |
| $\max(\text{NUSR}, \text{CUSR}, \text{SENF}, \text{PHYS}, \text{FNET}) = 2$ | High       | RO-1, OT-1, MOB-1, PC-*, LA-*, PS-1, SE-* |

| Risk factors                                      | Impact | Security profiles                               |
|---------------------------------------------------|--------|-------------------------------------------------|
| $\max(\text{SNDS}, \text{SNDT}, \text{SENF}) = 0$ | Low    | LR, IoT-1                                       |
| $\max(\text{SNDS}, \text{SNDT}, \text{SENF}) = 1$ | Medium | IoT-2, IoT-3                                    |
| $\max(\text{SNDS}, \text{SNDT}, \text{SENF}) = 2$ | High   | RO-1, OT-1, MOB-1, WE-1, PC-*, LA-*, PS-1, SE-* |



# Each threat must be mitigated according to risk factors

Requirements that mitigate this threat: **SSDD**, SDEF, MSAF, LMII, LMAS, LOGG

Mitigations for Likelihood:

Medium to Low: **SSCA**, **SCFS**, MMAC, ADEF

High to Low: **SSCA**, (**FZ95** or **BTIN** or **IMSL**), **SCFS**, MMAC, ASLR, MSAF-\*, MZRO-\*, MRWX-\*, NKAM, PLLC, MRCO, ADEF, JSTY

Mitigations for Impact:

Medium to Low: LOGG

High to Low: LOGG

# Each security profile has required mitigations, based on risk factors

## 5.3.2 SP-LR required mitigations

None.

## 5.3.3 SP-IoT-1 required mitigations

None.

[...]

## 5.3.7 SP-OT-1 required mitigations

**SSCA, (FZ95 or BTIN or IMSL), SCFS [...]**

# Assessment Procedure Structure

**Each requirement includes clear testing criteria:**

- Requirement Statement
- Activities - Step-by-step verification: review documentation, examine config, test functionality
- Verdict - Clear pass/fail criteria
- Supporting Evidence - Required documentation: manufacturer docs, configuration files, test results, log entries

# Assessment Example: Static source code analysis for memory errors

## 5.2.2.2 MI-SSCA: Static source code analysis for memory errors

All security-relevant parts of the product shall be checked for memory errors using a source code analysis tool that detects code that may produce common memory errors [...]

The sufficiency of the source code analysis tool and the selected manner of running it shall be documented.

All warnings, annotations, or other method of suppressing warnings from the analysis tool shall be documented with a rationale for why it does not constitute an unacceptable risk.

# Assessment Example: Static source code analysis for memory errors

Activities: Review the documentation on why the source code analysis tool is sufficient, how it is run, the source code for the product, the output of the source code analysis tool, and the documentation for any warnings or suppression of warnings

Verdict: Sufficiency documentation is acceptable, the method of running the tool is consistent with rationale, the output of source code analysis tool is consistent with the source code, all warnings or suppression of warnings have convincing documentation for why they are an acceptable risk => PASS, otherwise FAIL

Evidence: The documentation on why the source code analysis tool is sufficient, how it is run, the source code for the product, the output of the source code analysis tool, and the documentation for any warnings or suppression of warnings

# I don't want to share my source code

## CRA Article 53

### Access to data and documentation

Where necessary to assess the conformity of products with digital elements and the processes put in place by their manufacturers with the essential cybersecurity requirements set out in Annex I, **the market surveillance authorities shall, upon a reasoned request, be granted access to the data**, in a language easily understood by them, required to assess the design, development, production and vulnerability handling of such products, including related internal documentation of the relevant economic operator

# Key Principles

## Design Philosophy

- Each requirement analysed for feasibility - implementation costs considered
- Risk factors create natural consequences
- Standard allows product diversity - simple products face fewer and less complex conditional requirements
- Requirements are objective and testable - third-party assessors can verify consistently

# Areas Requiring Stakeholder Feedback

## Your input is critical for:

- More use cases! We don't have nearly enough
- Risk factor completeness - additional product vulnerabilities to address?
- More requirements - many are very high level and not useful to vendors
- Requirement feasibility - implementable and cost-effective?
- Assessment procedures - verification methods clear and executable?
- Cross-vertical alignment - common approaches for cryptography, updates, SBOM, auth
- Product scope boundaries - clear managed vs unmanaged distinction

**No clause is written in stone - all may be improved based on industry expertise.**



# How to Participate

## Access Draft Documents

- ETSI Open Area: <https://docbox.etsi.org/CYBER/EUSR/Open>

## Collaborative Technical Discussion

- ETSI Labs: <https://labs.etsi.org/rep/stan4cra/en-304-626/-/issues>

## Active Stakeholder Engagement

- Submit comments and propose improvements
- Engage in debates to refine standards
- Participate in open consultations

# Q&A





**Thank you for your attention!**



Co-funded by  
the European Union

Follow us on:

